RECURSOS DE SEGURANÇA

Controles de segurança implementados e seus testes funcionais. "Resultado" conforme verificado neste sistema (modo seguro).

ID	Tipo	Recurso	Componente	Descrição	Testes funcional	Resultado	Sugestão de Correção (caso positivo)
1	Funcional	Senha	Tabela usuarios	Senha armazenada com hash bcrypt (custo 12) + salt	Verificar no banco se senha_hash está no formato $2b$...	OK — bcrypt	—
2	Funcional	Senha	Criação de senha	Mínimo de oito caracteres	Tentar cadastrar/trocar com menos de 8 caracteres	OK — recusado	Corrigir validação no processo
3	Funcional	Senha	Criação de senha	Exigir número, letra maiúscula e símbolo	Cadastrar sem cada item; testar símbolos - , < > e espaço	OK — recusado	Corrigir validação no processo
4	Funcional	CPF	Dados sensíveis	Cifrar CPF no banco (AES-256-GCM)	Ver no banco (ilegível) e decifrar na tela "Minha conta"	OK — cifrado	Cifrar nas rotinas que gravam
5	Funcional	Cartão	Tabela pagamentos	Cifrar número do cartão; NÃO armazenar CVV	Ver cartao_cifrado ilegível; confirmar ausência de CVV	OK — cifrado / sem CVV	Cifrar PAN; remover CVV
6	Funcional	Telefone	Dados sensíveis	Cifrar telefone no banco	Verificar telefone_cifrado ilegível no banco	OK — cifrado	Cifrar ao gravar
7	Funcional	Sessão	Cookie de sessão	Cookie httpOnly, secure e SameSite; regenerar no login	Inspecionar o cookie "sid" no navegador (DevTools)	OK	Ajustar flags do cookie
8	Funcional	CSRF	Formulários	Token anti-CSRF por sessão em cada formulário	Enviar POST sem o campo _csrf	OK — HTTP 403	Adicionar token aos forms
9	Funcional	Controle de acesso	Pedidos	Verificar posse do pedido (anti-IDOR) e papéis (RBAC)	Acessar pedido de outro usuário; acessar /admin sem ser admin	OK — HTTP 403	Validar dono/papel no backend
10	Funcional	Força bruta	Login	Rate limit (5/15min) + bloqueio de conta após 5 falhas	Errar a senha 6 vezes seguidas	OK — bloqueio/429	Rate limit + lockout
11	Funcional	Cabeçalhos	HTTP (Helmet/nginx)	CSP, HSTS, X-Frame-Options, X-Content-Type-Options	Inspecionar cabeçalhos da resposta	OK — presentes	Habilitar Helmet/headers
12	Funcional	Auditoria	logs_auditoria	Registrar login, falha, compra e acesso negado (IP/UA)	Consultar a tabela logs_auditoria após as ações	OK — registrando	Centralizar e monitorar logs